Kestrel loan platform on AWS: production

Account 768499314608, region eu-west-1 (Ireland). Dev is the same code with different variables (one AZ for endpoints, smaller tasks, single AZ database).

Request and data flow (numbered in order)
Control, deploy and audit paths
TLS encrypted in transit
KMS encrypted at rest (key named)

Customers
Web and mobile apps
180,000 customers

1 TLS

GitHub Actions
Lint, test, build, scan
Plan on PR, apply on merge
Prod needs approval issue
No stored AWS keys

Operators (3)
Alarm email, dashboard, runbook (docs/runbook.md)

AWS REGION eu-west-1

VPC 10.30.0.0/16 (no NAT gateway, no internet route from private or isolated subnets)

AVAILABILITY ZONE eu-west-1a | AVAILABILITY ZONE eu-west-1b

PUBLIC SUBNETS 10.30.0.0/24, 10.30.1.0/24

WAF
3 AWS rule groups, rate limit per IP

Application Load Balancer (both AZs)
HTTPS 443, TLS 1.3 and 1.2 (restricted ciphers). Port 80 only redirects to HTTPS.
Certificate in ACM (self signed until the client gives a domain, ADR 0008)
Health checks on GET /health

2

PRIVATE SUBNETS 10.30.10.0/24, 10.30.11.0/24

ECS Fargate: loan API tasks
0.5 vCPU, 1 GB, non root user. 2 to 20 tasks across both AZs
Scales on requests per task and CPU; floor of 5 on 25th to 28th
Own task role: encrypt and hash BVN, never decrypt

Lambda: scorer
Network interfaces in both AZs, at most 5 at once
Approve if amount is at most 3 x salary
Row lock makes a repeated message harmless

4

VPC endpoints (one per service in each AZ): the only way out of the private subnets
Interface endpoints: ecr.api, ecr.dkr, logs, secretsmanager, kms, sqs, sns. Security group allows HTTPS from the VPC only.
S3 gateway endpoint (free): image layers and the artifacts bucket (ADR 0006).
TLS on every call to an AWS service. A compromised task cannot reach the internet to send data out.
Fixed cost about USD 112 a month in prod instead of NAT gateways and their data charges.

3 6

ISOLATED DATABASE SUBNETS 10.30.20.0/24, 10.30.21.0/24

RDS PostgreSQL 16: primary
db.t4g.micro, gp3 storage, not public
Accepts connections only from the API and scorer
Backups 7 days, point in time restore (RPO about 5 min)
KMS data key. BVN stored only as ciphertext plus HMAC.
TLS required (rds.force_ssl = 1)

RDS standby (Multi-AZ)
Synchronous copy of the primary
Automatic failover in 1 to 2 minutes
if eu-west-1a or the primary fails
KMS data key

5

REGIONAL SERVICES (reached through the endpoints)

SQS scoring queue + dead-letter queue
A message per application. After 3 failed tries it moves to the DLQ;
any message there raises an alarm.
SSE SQS managed encryption

SNS loan decisions topic
Other teams subscribe without code changes.
KMS AWS managed SNS key

7

KMS customer managed keys
data: database, its password secret, backups
bvn-encrypt: BVN ciphertext (no role can decrypt today)
bvn-mac: HMAC lookup hash, key never leaves KMS (ADR 0007)
Yearly rotation (except HMAC), 7 day deletion wait, uses logged

Secrets Manager
Database password created and rotated every 7 days by RDS.
Not in code, env files or Terraform state.

ECR image repository
Scan on push; pipeline stops on a critical finding.
AES AES-256 at rest (code, no customer data)

CloudWatch
JSON logs with one request ID from API to queue to scorer.
BVN masked; request bodies never logged. 30 day retention.
Dashboard: requests, errors, p95, queue, DLQ, database.
Alarms: 5xx rate, p95 latency, any DLQ message, low storage,
each linked to a runbook entry. Also VPC Flow Logs, WAF logs.
Alarm topic (SNS) sends email to the operators.

ACCOUNT GOVERNANCE AND SECURITY (terraform/account and bootstrap, applied once)

CloudTrail (all regions)
Who did what, including every KMS use.
Log file validation on.

S3 audit log bucket
Application roles cannot write or delete.
Only named log admins can delete.
KMS cloudtrail key, versioning on

Threat and posture checks
GuardDuty: threat detection
Security Hub: AWS best practice checks
Config: records every change
Score 90% on 16 Oct, gaps explained

Deploy access and cost
OIDC roles: plan, deploy dev, deploy prod
Terraform state in S3, encrypted, locked
AWS Budget USD 40 with email alerts
Tags: Environment, Owner, CostCenter

GitHub OIDC: short lived deploy role, no stored keys

Every resource is created by Terraform from one root module (terraform/platform). Prod differs from dev only in terraform/envs/prod/terraform.tfvars.
Account settings: EBS encryption by default, S3 public access blocked for the whole account, IAM password policy, no public sharing of SSM documents.
Nothing runs outside eu-west-1. Dashboards are a global console view of eu-west-1 metrics.

Alarm email to operators

Flow of one application

1 Customer sends POST /applications over HTTPS; WAF filters it

2 ALB forwards to a task inside the VPC

3 Task stores the application as PENDING, BVN encrypted

4 Task calls KMS for the BVN and puts a message on SQS

5 SQS triggers the scorer

6 Scorer locks the row and saves the decision

7 Scorer publishes the decision to SNS

Customer polls GET /applications/{id}: seconds, not overnight